

Clase 040 — Man-in-the-Middle: técnicas y defensa

Parte: 1 — Redes y seguridad de redes · Fuente: OWASP; documentación de bettercap y mitmproxy 🕒

Duración estimada: 130 min · Nivel: Avanzado

Objetivo

Integrar lo aprendido en un ataque **Man-in-the-Middle** completo: posicionamiento (ARP/DNS spoofing, rogue gateway), interceptación de tráfico, intentos de degradación de TLS y, sobre todo, las **defensas** que lo derrotan (HSTS, certificate pinning, cifrado extremo a extremo, DAI). El énfasis es entender el ataque para saber defender.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Describir** las fases de un ataque MitM y sus puntos de posicionamiento.
2. **Interceptar** y modificar tráfico HTTP con un proxy transparente en laboratorio.
3. **Explicar** por qué TLS bien implementado frustra el MitM y qué es SSL stripping.
4. **Reconocer** los indicadores de un MitM en curso.
5. **Aplicar** defensas: HSTS, HPKP/pinning, DNSSEC, DAI, VPN.
6. **Evaluar** el riesgo residual en redes no confiables (WiFi público).

Temas

#	Tema	Por qué importa
1	Anatomía del MitM	Marco mental del ataque
2	Posicionamiento (ARP, DNS, rogue AP)	Cómo se interpone el atacante
3	Interceptación con proxy transparente	Ver y modificar el tráfico
4	SSL stripping y su mitigación	El punto débil histórico
5	HSTS, pinning, E2E	Defensas efectivas
6	Indicadores y detección	Reconocer un MitM
7	Redes no confiables	Riesgo real cotidiano

Definiciones y características

- **MitM:** el atacante se sitúa entre dos partes, retransmitiendo (y opcionalmente alterando) su comunicación sin que lo noten.
- **SSL stripping:** degradación de HTTPS a HTTP interceptando la conexión inicial; se mitiga con HSTS.
- **HSTS (HTTP Strict Transport Security):** cabecera que obliga al navegador a usar solo HTTPS para un dominio, evitando el stripping.

- **Certificate pinning:** la aplicación acepta solo un certificado/clave concretos, de modo que un certificado falso del atacante es rechazado.
- **Rogue gateway / evil twin:** puerta de enlace o AP falso que canaliza el tráfico de la víctima por el atacante.
- **DNSSEC:** firma las respuestas DNS para evitar su falsificación (se amplía en la clase 041).

Herramientas y preparación

- **bettercap** (framework MitM), **mitmproxy** (proxy HTTP/HTTPS interactivo), **sslstrip** (histórico).
- Wireshark para verificar el cifrado.
- Laboratorio con víctima, atacante y un servidor web propio (uno con HSTS, otro sin) para comparar.

 **Nota ética:** el MitM intercepta comunicaciones de terceros; hacerlo sin autorización es un delito grave. Practica **solo** contra tus propias máquinas y servicios en un laboratorio aislado. El objetivo formativo es defensivo: entender el ataque para neutralizarlo.

Laboratorio guiado

1. **Posiciónate** como MitM por ARP spoofing (repaso de la clase 039) con bettercap y activa el sniffing.
2. **Intercepta HTTP** con mitmproxy en modo transparente:

```
bash sudo sysctl -w net.ipv4.ip_forward=1 sudo iptables -t nat -A PREROUTING -i eth0 -p tcp --dport 80 -j REDIRECT --to-port 8080 mitmproxy --mode transparent --listen-port 8080
```

Navega desde la víctima a tu servidor HTTP de laboratorio y observa/modifica las peticiones. 3. **Prueba SSL stripping** contra el servidor **sin** HSTS y observa que la conexión cae a HTTP. 4. **Repite contra el servidor con HSTS** y comprueba que el navegador **rechaza** el downgrade: el ataque falla. 5. **Verifica el cifrado:** en Wireshark, confirma que el tráfico HTTPS con TLS bien configurado es opaco para el atacante. 6. **Certificado falso:** intenta un MitM sobre HTTPS presentando un certificado no confiable y observa la advertencia del navegador (defensa por la cadena de confianza). 7. **Defensa de red:** activa DAI/ARP estático (clase 039) y demuestra que ya no puedes posicionarte.

Ejercicios

1. Intercepta y modifica una respuesta HTTP (p. ej. cambia un texto de la página) con mitmproxy en laboratorio.
2. Compara el resultado del stripping en un sitio con HSTS y otro sin él.
3. Explica por qué el pinning protege a una app móvil aun con un certificado "válido" del atacante.
4. Identifica en una captura los indicadores de un MitM (cambios de MAC del gateway, certificados anómalos).
5. Configura HSTS con `preload` en tu servidor y verifica la cabecera con `curl -I`.
6. Argumenta cómo una VPN (clase 036) reduce el riesgo de MitM en WiFi público.

Reto verificable

Monta en laboratorio un escenario MitM contra dos versiones de tu propio sitio: una vulnerable (HTTP/sin HSTS) y otra endurecida (HTTPS + HSTS). Demuestra que puedes interceptar/modificar la primera y que la

segunda resiste el ataque. Entrega capturas, la configuración de HSTS y una conclusión sobre qué defensa fue decisiva.

Criterio de aceptación: evidencias claras de interceptación exitosa en la versión vulnerable y de fallo del ataque en la endurecida, con explicación correcta del mecanismo defensivo (HSTS impide el downgrade; TLS válido impide leer el contenido).

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
mitmproxy no ve tráfico	Falta el REDIRECT de iptables o <code>ip_forward</code> ; revisa NAT y reenvío
El navegador muestra advertencia de certificado	Es la defensa funcionando; sin la CA del atacante instalada, TLS rechaza el MitM
SSL stripping no funciona	El sitio usa HSTS/preload; ese es precisamente el resultado esperado
La víctima pierde conexión	Reenvío mal configurado; verifica que retransmites el tráfico interceptado
No puedes modificar HTTPS	El cifrado lo impide sin un certificado de confianza; no es un fallo, es seguridad

Preguntas frecuentes

? ¿HTTPS elimina el riesgo de MitM? Lo reduce enormemente si está bien implementado (certificados válidos, HSTS, TLS moderno). El riesgo residual viene de usuarios que ignoran advertencias o de CAs comprometidas; el pinning cubre esos casos.

? ¿Qué es exactamente SSL stripping? Un ataque que impide que la víctima llegue a establecer HTTPS, manteniéndola en HTTP con el atacante en medio. HSTS lo neutraliza porque el navegador exige HTTPS de antemano.

? ¿Cómo detecto que soy víctima de un MitM? Advertencias de certificado inesperadas, cambios en la MAC del gateway, degradación a HTTP en sitios que deberían ser HTTPS, o certificados emitidos por CAs raras.

? ¿La mejor defensa personal en WiFi público? Usar siempre HTTPS/HSTS, una VPN de confianza y evitar aceptar certificados o instalar CAs que te pidan redes desconocidas.

Referencias

- OWASP — Man-in-the-Middle Attack. https://owasp.org/www-community/attacks/Manipulator-in-the-middle_attack
- mitmproxy documentation. <https://docs.mitmproxy.org/>
- RFC 6797 — HTTP Strict Transport Security (HSTS). <https://www.rfc-editor.org/rfc/rfc6797>
- MITRE ATT&CK — Adversary-in-the-Middle (T1557). <https://attack.mitre.org/techniques/T1557/>

Siguiente clase

Clase 041 - Seguridad de DNS: envenenamiento, DNSSEC y tunneling